

 Institución Universitaria Centro de Laboratorios	GUÍA DE TRABAJO PRÁCTICO	Código	FDE 048
		Versión	03
		Fecha	2009-06-09

1. IDENTIFICACIÓN DE LA GUÍA

Asignatura	Gestión de vulnerabilidades en aplicaciones	Guía No.	1
Programa	Especialización en Ciberseguridad		
Docente	Javier Mauricio Durán Vásquez		

COMPETENCIA	CONTENIDO TEMÁTICO	RESULTADO DE APRENDIZAJE
El estudiante formula estrategias para gestionar las vulnerabilidades técnicas en aplicaciones, reduciendo sus posibles riesgos de exposición, a través de la validación de impactos sobre los sistemas.	Elaboración de informes individuales que documenten la identificación, clasificación y análisis de amenazas y vulnerabilidades en aplicaciones web, empleando estándares como OWASP Top 10, CVE y CWE.	RAE3: Determina mecanismos de protección en los sistemas computacionales, redes informáticas o de computadores, a través de la conceptualización de los ataques, controles y/o buenas prácticas nacionales o internacionales.

2. OBJETIVO(S)

- Desarrollar la capacidad de comprender de manera crítica las principales vulnerabilidades web, sus mecanismos de explotación y el ciclo completo de un ataque, desde la identificación hasta la materialización del riesgo, con el fin de consolidar una visión práctica y aplicada de la seguridad en aplicaciones web.
- Fomentar en los estudiantes la habilidad de analizar y proponer medidas de mitigación efectivas alineadas con buenas prácticas y marcos de referencia de seguridad (como OWASP Top 10), de manera que puedan transferir lo aprendido en la aplicación web vulnerable a escenarios reales en el ámbito profesional.

3. RECURSOS REQUERIDOS

- Software virtualizador VMWare o VirtualBox
- Máquina virtual con el O.S Kali Linux (*HD 20GB --- RAM 2GB*)
- Máquina virtual con el O.S Metasploitable (*HD 20GB --- RAM 256MB*)
- Aplicación DVWA (*Preinstalada en Metasploitable*)

Nota: Para la práctica no es necesario disponer de conectividad a Internet, pero si es recomendado algún dispositivo que cumpla funciones de servidor DHCP para otorgar direcciones IP a las máquinas. Si lo desea también puede utilizar direccionamiento estático.

 Institución Universitaria Centro de Laboratorios	GUÍA DE TRABAJO PRÁCTICO	Código	FDE 048
		Versión	03
		Fecha	2009-06-09

4. PROCEDIMIENTO O METODOLOGÍA PARA EL DESARROLLO

En este laboratorio usted asumirá el rol de **auditor de seguridad de aplicaciones o pentester (hacker ético)**, encargado de identificar, explotar y documentar vulnerabilidades presentes en la aplicación **DVWA**. Para ello deberá disponer de sus propias máquinas virtuales y realizar los ejercicios prácticos de forma controlada.



A manera de evidencia, deberá presentar un informe documentado que incluya capturas de pantalla con la fecha visible, acompañadas de comentarios en los que relate sus hallazgos y análisis.

Es importante tener en cuenta que los comentarios solicitados no deben redactarse como un tutorial paso a paso, sino como una descripción técnica y reflexiva de los ataques realizados y de las conclusiones obtenidas. Cada captura debe estar acompañada de un texto explicativo.

Elementos requeridos en la entrega

Para cada vulnerabilidad trabajada, el informe debe contener:

1. **Título** de la vulnerabilidad (ejemplo: SQL Injection).
2. **Descripción breve** de la vulnerabilidad en sus propias palabras.
3. **Causas de la vulnerabilidad / debilidad:** explicación o demostración (mediante fragmento de código) de cómo la vulnerabilidad surge por:
 - a. Ausencia de validaciones
 - b. Errores de lógica
 - c. Manejo inadecuado de entradas o salidas de datos
4. **Mecanismo de ataque:** explicación clara de las acciones ejecutadas para la explotación.
5. **Capturas de pantalla** del proceso y resultados obtenidos (con fecha visible).
6. **Clasificación técnica:** referencia a CWE y/o CVE relacionado.

	GUÍA DE TRABAJO PRÁCTICO	Código	FDE 048
		Versión	03
		Fecha	2009-06-09

7. **Impacto** esperado en un sistema real (afectación a la confidencialidad, integridad y/o disponibilidad).
8. **Propuesta de mitigación:** controles de seguridad, buenas prácticas o defensas aplicables.

Al final de cada informe incluya una reflexión personal sobre lo aprendido y su relevancia para la práctica profesional en seguridad de aplicaciones.

Nota importante sobre el prompt en Kali Linux

Con el fin de verificar la autoría de las evidencias, el **prompt de su máquina virtual Kali Linux debe incluir su nombre y apellido**

ejemplo: `jduran@kali:~$` → `javierduran@kali:~$`

Existen dos formas sencillas de lograrlo:

1. Cambiar el nombre de usuario

Si crea un nuevo usuario con su nombre y apellido (sin espacios), el prompt reflejará automáticamente este valor:

```
sudo adduser javierduran
```

```
su - javierduran
```

2. Cambiar el hostname del sistema

Si desea que el nombre de la máquina también muestre su nombre y apellido:

```
sudo hostnamectl set-hostname nombreapellido
```

5. ENTREGABLES DEL LABORATORIO

El trabajo práctico se desarrollará en dos entregas que deberán ser presentadas en formato de informe siguiendo los lineamientos establecidos en los elementos requeridos.

INFORME #1 (Individual)

Fecha de entrega: 28 de febrero de 2026

Contenido: Evidencias de ataques y vulnerabilidades trabajadas:

1. XSS Reflejado

Muestre el payload y el proceso para robar una cookie y cargarla en el navegador del atacante para iniciar una sesión sin necesidad de conocer el usuario y contraseña de la víctima

	GUÍA DE TRABAJO PRÁCTICO	Código	FDE 048
		Versión	03
		Fecha	2009-06-09

2. XSS Almacenado

Muestre el payload y para provocar una redirección persistente hacia otro sitio web, cada vez que el usuario ingrese a la funcionalidad de foros en XSS (Stored)

3. Upload Backdoor

Muestre el proceso para preparar y cargar un archivo malicioso que le permita iniciar una sesión de consola de sistema operativo

4. CSRF

Muestre el proceso para falsificar una petición en sitios cruzados que le permita modificar un dato, parámetro, configuración o credencial de la víctima

INFORME #2

Fecha de entrega: 14 de marzo de 2026

Contenido: Evidencias de ataques y vulnerabilidades trabajadas:

5. File Inclusion (LFI, RFI)

Muestre el payload y el proceso para explotar una vulnerabilidad File incursión tipo LFI y una vulnerabilidad File Inclusion tipo RFI

6. Command Execution (Command Injection)

Muestre el payload y el proceso para provocar ejecución de comandos no autorizados a nivel del sistema operativo de la víctima, a través de la vulnerabilidad de Command Injection en DVWA

7. Fuerza Bruta

Muestre los comandos y el proceso para ejecutar un ataque de fuerza bruta sobre la sección que presenta esta vulnerabilidad.

8. SQL Injection & SQL Injection(Blind)

Muestre los comandos y el proceso para ejecutar un ataque de SQL Injection sobre la sección que presenta esta vulnerabilidad.

Consideraciones importantes para ambos informes

- Cada estudiante deberá documentar las vulnerabilidades siguiendo la estructura definida en la guía (elementos requeridos en la entrega)
- Las capturas de pantalla deben mostrar **fecha visible y personalización del prompt en Kali Linux con nombre y apellido**.
- Los comentarios deben ser de carácter **técnico y reflexivo**, no un tutorial paso a paso.
- En la sección de “Causas de la vulnerabilidad”, se espera que el estudiante explique o ejemplifique cómo la debilidad surge por ausencia de validaciones, errores de lógica o prácticas inseguras en el código.